

4.5 - Autenticação vs autorização

Dois conceitos, uma classe inteira de falhas

O motorista que via rotas alheias

- **Bug da seção 1 revisitado com diagnóstico completo**
 - Motorista acessava rotas de outra transportadora

LUNALOG

O bug do motorista que enxergava as rotas de outro motorista, mencionado lá na seção 1, voltou agora com diagnóstico completo. O sistema verificava corretamente que o usuário estava autenticado, ele era quem dizia ser. O que o sistema nunca verificou foi se aquele usuário autenticado tinha autorização para acessar aquela rota específica, de outra transportadora. O código misturava os dois fluxos numa única função de duzentas linhas, e foi exatamente essa confusão que abriu a vulnerabilidade. Ana percebeu que o problema não era um bug, era um erro conceitual virado design.

Duas perguntas que não se misturam

Quem é você e o que você pode fazer

- **Autenticação responde quem é você**
 - Valida identidade por senha, token ou certificado
- **Autorização responde o que você pode fazer**
 - Avalia permissões depois da identidade confirmada
- **A ordem importa: autenticar antes de autorizar**
 - Autorizar sem antes autenticar não faz sentido
- **Misturar os dois fluxos cria vulnerabilidade sistêmica**
 - Um acerto na identidade esconde a falha na permissão

Por que a confusão é tão perigosa

- **Sistemas testam login e esquecem de testar permissão**
- **Acesso negado por identidade é óbvio, por permissão não**

Broken access control é a falha número um do OWASP. Quase sempre nasce de autorizar com a lógica de autenticação, confiar que estar logado já basta.

- Autorização precisa de checagem própria em cada recurso

Autenticação e autorização lado a lado

Autenticação

- Pergunta: quem é você
- Acontece uma vez, no início da sessão
- Resultado: identidade confirmada
- Mecanismos: senha, MFA, certificado, token

Autorização

- Pergunta: o que você pode fazer
- Acontece em cada acesso a recurso
- Resultado: permitido ou negado
- Mecanismos: papéis, atributos, políticas

| Identity provider separa identidade do consumo

- **IdP centraliza a gestão de identidades em um lugar**
 - Sistemas consomem identidade sem armazenar senha
- **Aplicação confia no IdP, não reimplementa login**
 - Reduz superfície de ataque e duplicação de lógica
- **Separação clara entre emitir e consumir identidade**
 - Esse desenho é a base de OAuth, OIDC e SSO
- **Autorização continua responsabilidade de cada aplicação**



Autenticação e autorização agora são conceitos separados e nítidos na sua cabeça. Mas como isso vira implementação real, com múltiplos clientes, identidades corporativas e fluxos de delegação entre sistemas que não confiam um no outro? Existe um conjunto de protocolos que define exatamente como a identidade circula na web hoje.

OAuth 2.1 e OpenID Connect na prática